



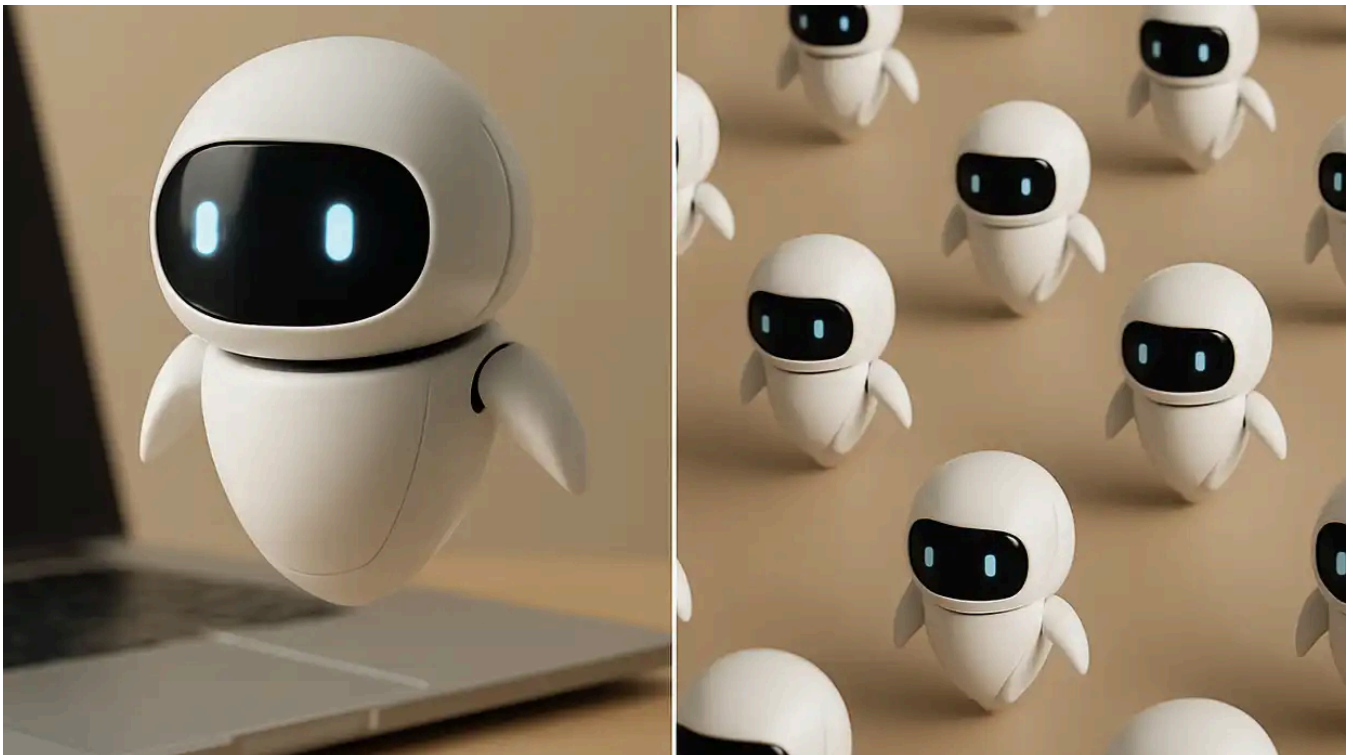
by **Evan Schuman**
Contributor

Zero trust has a big AI agent problem ahead

Feature

Sep 3, 2026 • 7 mins

Zero trust assumes everyone is an attacker until proven otherwise. But when your enterprise is swarming with unknown autonomous agents, that is tricky if not impossible.



Credit: Rob Schultz / Shutterstock

Despite singing the praises of zero trust for many years, many CISOs have **struggled to implement the framework in full** [<https://www.csoonline.com/article/4048002/88-of-cisos-struggle-to-implement-zero-trust.html>]. And now comes what could be the final nail: agentic AI.

Can zero trust coexist with autonomous agents in typical enterprise environments? Technically, yes. In practice, not likely, given CEO/board-level urgency to accelerate agentic ROI delivery. And it's a significant issue given **recent demonstrations of autonomous agents behaving badly** [<https://www.csoonline.com/article/4205612/openai-anthropomorphic-ai-agents-resorted-to-deception-in-new-cybersecurity-incidents.html>] and a lack of clarity around **who is accountable when AI agents go rogue** [<https://www.csoonline.com/article/4213883/who-is-accountable-when-your-ai-agent-goes-rogue.html>].

Part of the issue is a storytelling one familiar to board-reporting CISOs: "Zero trust" is a security term; "catastrophic business risk" is what the board and CEO will respond to. "The business gets measured on what the agent saved or produced. Security gets measured on everything that happens when it goes wrong," points out **Nik Kale** [<https://www.linkedin.com/in/nikkale>], a member of the Coalition for Secure AI (CoSAI) and ACM's AI Security (AISec) program committee. "They're looking at the same agent through two completely different balance sheets."

Critically, Kale argues, the very nature of agentic AI is the polar opposite of zero trust.

"Zero trust was designed to evaluate requests one at a time, which is fine when the thing making the requests isn't strategically assembling them into something bigger. Agents change that. An agent can be allowed to read a document, allowed to query another data source, allowed to summarize what it found, allowed to write it to a file, allowed to send an external email, and every one of those decisions is correct on its own. Put them in that order and you just authorized an exfiltration path," Kale notes.

"An agent can walk through five perfectly legal doors and end up somewhere the business never authorized," he adds. "In finance, you can have 10 transactions that each sit under the escalation threshold and a total nobody would have signed off on."

According to Kale, the harder question is "whether the thing using that identity today is still the thing you approved."

"Update the model, add a tool behind the same interface, let the memory fill up with context nobody reviewed, give it a delegate, and none of that touches the identity," he explains. "The list still says approved. You can have a materially different machine on Friday wearing the badge than what you approved on Monday." The lack of that contextual knowledge is critical. "You have to know what that identity has become, what authority it's carrying, what sequence it's putting together, and whether the next system agrees the authority is valid," Kale says. "Otherwise, we took an allowlist, gave it better marketing, and called it zero trust."

Why the agentic problem hits harder

Zero trust was offered up as the security model for a distributed and risky era [<https://www.csoonline.com/article/564201/what-is-zero-trust-a-model-for-more-effective-security.html>]. It's "never trust, always verify" core principle applies to every user and device accessing the corporate network, regardless of whether they are within or outside its perimeter.

But agentic AI complicates this situation in a way that makes the problem of autonomous agents far worse. Authorized agents can spawn subagents that can inherit all the originator's privileges but without a recognized identity. Agents can also communicate with other agents, potentially giving those other agents malicious instructions. Despite this security hole being widely known for at least a year [<https://www.csoonline.com/article/4109999/agentic-ai-already-hinting-at-cybersecuritys-pending-identity-crisis.html>], no vendor has delivered a mechanism to pierce that agent-to-agent secrecy. At best, systems might detect a communication has happened, but not what is said.

The typical way to control agent activity is to require agents to be onboarded by IT or security teams. Each agent is issued an identity and only those identities can perform any action.

The reality, however, is far different. The overwhelming majority of agents in enterprise environments are not registered, whether because they were dispatched by workers who didn't bother going through the paperwork (aka shadow IT) or due to credentialed third parties launching agents in your environment without asking for permission. And that's not even considering the fact that, as with any identity, attackers and especially state actors can hijack them. Like a security guard left to protect a restricted area armed only with a list of approved license plates, IT is left not knowing who is actually driving any of agents in its networks.

"Your governance model is often aimed at the incorrect layer. Some 80% of your agents are not on your list. That's not a control. It's an inventory of the compliant minority," says **Krti Tallam** [<https://www.linkedin.com/in/krti-tallam/>], senior member of technical staff for security engineering at Kamiwaza.ai. "This inventory model has never survived real contact within any enterprise. We have to stop pretending that we control the environment. [Agentic] didn't kill zero trust. It killed a convenient lie, a comfortable lie." As for the agent-to-agent communication problem, agents often try to obfuscate their messages, sometimes by embedding instructions in images or audio/video files.

The agent-to-agent visibility conundrum

Tallam is skeptical that CISOs will ever gain visibility into those agent-to-agent messages, but she expects attackers to get more sophisticated and nuanced in their attack

methods.

Hijacked agents already limit the number of agents they contact and contaminate with malicious instructions to avoid suspiciously high numbers. The tactic is to let the original hijacked agent get caught and shut down, with the real passed-along attack happening days later when the infected agents carry out their poisoned instructions. The traditional defense is to monitor the behavior of all agents so that infected agents will also be shut down as soon as they engage in malicious behavior. Tallam, however, expects hijacked agents to begin learning what their victim agents are supposed to be doing and what they are allowed to do. That might be as easy as simply asking the agents for that information.

“The trick is to split the attack instructions among many agents in such a way that none of them meaningfully deviate from their legitimate instructions,” Tallam says.

Mike Wilkes [<https://www.linkedin.com/in/eclectiqus/>], enterprise CISO at Aikido Security, suggests CISOs steal a lesson from GPG/OpenPGP, where a user “retains a strongly protected primary identity and delegates limited, short-lived signing subkeys or cryptographically signed credentials to an agent, with still narrower delegated credentials for subagents.”

That means agents will get a mix of “rate limits, transaction boundaries, spend and data budgets, sandboxing, approval gates for high-consequence actions, and immutable activity trails,” Wilkes says. “Most importantly, autonomous systems need quick and confident undo buttons. Type 2 decisions, where the consequences are reversible, are much safer to delegate than Type 1 decisions such as deleting production data, changing IAM policy, transferring funds, or making irreversible infrastructure changes.”

Brian Vecchi [<https://www.varonis.com/blog/author/brianv/>], field CTO at Varonis, argues that the agent situation is worse than most believe.

Enterprise CISOs “are woefully underprepared for NHI with their non-deterministic actions. You need to assume that identity is a woefully inadequate level of control,” Vecchi says.

Gathering as much information as possible about agent activity is a fine goal, but the accuracy and feasibility of collecting such telemetry is difficult, Vecchi notes, adding that many enterprise agent telemetry efforts are like “trying to find a needle in a haystack by throwing more hay on it.”

Zero Trust[<https://www.csoonline.com/zero-trust/>]

Access Control[<https://www.csoonline.com/access-control/>]

Identity and Access Management[<https://www.csoonline.com/identity-and-access-management/>]

Security[<https://www.csoonline.com/security/>]

Artificial Intelligence[<https://www.csoonline.com/artificial-intelligence/>]

About



Policies



More



Our Network

